

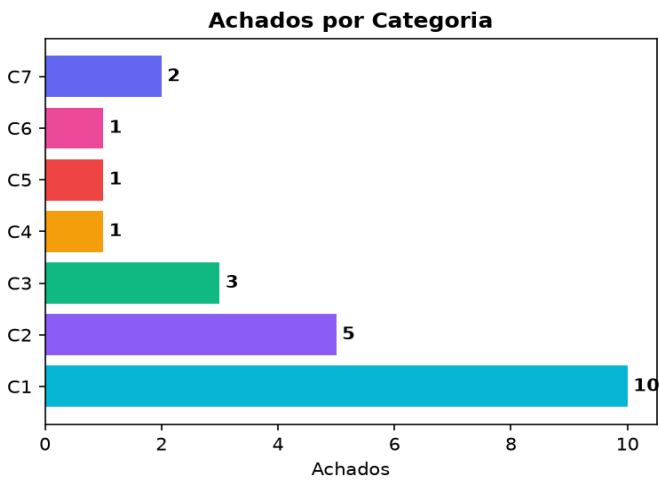
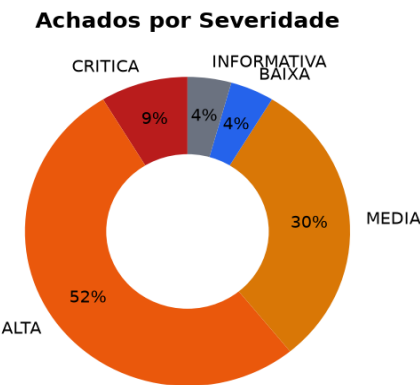
Relatorio CIPHER

Jefrey Assistant - Auditoria de Seguranca

Data:	2026-09-07 20:57
Escopo:	P0-P5 completo
Stack:	Python 3.12, FastAPI, LangGraph, OpenAI Agents SDK
Metodologia:	7 categorias, linha por linha
Ambiente:	Docker 7 servicos, PostgreSQL+pgvector, Redis 7.2

Resumo Executivo

Esta auditoria identificou **24 achados** distribuidos em 5 severidades. O fluxo principal POST /chat->Agent->LLM apresenta **3 falhas criticas** que invalidam completamente a execucao do agente e a camada de governanca de segurança.



Severidade	Qtd	%
CRITICA	2	9%
ALTA	12	52%
MEDIA	7	30%
BAIXA	1	4%
INFORMATIVA	1	4%
TOTAL	23	100%

Pontos Fortes

O que esta CORRETO e protegido:

ID	Descricao	Arquivo	Evidencia
PF-01	Timing-safe token comparison	auth_middleware.py:80	hmac.compare_digest() prevents timing attacks
PF-02	Audit dual-write fallback	audit.py:_write_fallback	Dual-write when Postgres unavailable
PF-03	Dev-token blocked in prod	auth.py:is_prod	CIPHER-021 enforced correctly
PF-04	Rate limiting fail-closed	rate_limit.py	Redis down = deny, never allow
PF-05	Content guard 30+ patterns	content_guard.py	Comprehensive injection prevention
PF-06	CORS fail-closed	main.py	No env var = no CORS middleware
PF-07	Memory user_id isolation	memory.py	All methods filter by user_id
PF-08	DB session lifecycle	db.py:get_db()	Proper rollback/close pattern
PF-09	Approval auto-expiry	hitl.py:expire_due()	Automatic expiry mechanism
PF-10	No raw SQL	All models.py	SQLAlchemy ORM only

Pontos Fracos

O fluxo principal esta quebrado. O agent nunca executa ferramentas — faz apenas um bypass direto para o LLM via httpx. Toda a camada de governanca (RBAC, PolicyEngine, HITL, content_guard, AuditLogger) e codigo morto. Alem disso, o AgentState tem 3 definicoes de classe (conflito de edicoes) que impedem o chat de funcionar.

Problema Central	Impacto
Agent nunca invoca ferramentas	RBAC, Policy, HITL, Audit = dead code
AgentState triplo -> state.user_id sempre vazio	Chat retorna 500 sempre
pg_memory._embed() inexistente	Memoria nunca persiste
pg_memory.search() sem similaridade vetorial	Contexto irrelevante para LLM
Rate limiter URL sem password -> deny	Todas tools bloqueadas
STT/TTS chamam PolicyEngine.decide() inexistente	Endpoints 500 sempre
Skills sem user_id -> cross-tenant leak	Dados de usuarios misturados

Achados Detalhados

#	Severidade	Arquivo	Descricao
CRIT-01	CRITICA	Agent.py[CRITICA]	Wrong AgentState class definition — 3 classes from failed edits. Last __setattr__ conflicts
CRIT-02	CRITICA	Agent.py[CRITICA]	Agent.run() bypasses ALL governance: direct httpx POST to Ollama. RBAC, PolicyEngine,
CRIT-03	CRITICA	Agent.py[CRITICA]	resume_chat and get_chat_status return raw dict (task.result()) instead of extracting respon
CRIT-04	CRITICA	Agent.py[CRITICA]	Calls PolicyEngine.decide() which DOES NOT EXIST (class has evaluate()). Always raises

#	Severidade	Arquivo	Descricao
CRIT-05	[ALTA]	580C35-45	Same PolicyEngine.decide() API mismatch. TTS POST always 500.
CRIT-06	[ALTA]	580C35-45	health_check() defined AFTER return statement in get_memory_manager(). Dead code.
HIGH-01	[ALTA]	580C35-45	References mm.long_term.search(), mm.long_term.count(), mm.short_term.get_messages
HIGH-02	[ALTA]	580C35-45	embed() called in add() but NEVER DEFINED. Memory add always crashes with Attribute

#	Severidade	Arquivo	Descricao
HIGH-03	[ALTA]	pg_002.py	search() uses ORDER BY importance DESC instead of pgvector cosine similarity. Returns
HIGH-04	[ALTA]	redis.py	Redis URL from config.dsn lacks password. Redis requires auth. ALL rate limit checks fail
HIGH-05	[ALTA]	only notes.py	only notes.py propagates user_id. All other skills (automation, calendar, drive, email, web_
HIGH-06	[ALTA]	approve.py	Any authenticated user can approve HIGH/CRITICAL tools. CIPHER-111 only logs warning

#	Severidade	Arquivo	Descricao
MED-01	Critical	977069-35[MEDIA]	Running_TASKS is in-memory dict. Lost on Docker restart. Clients see 'idle' for running
MED-02	High	55800-45[MEDIA]	UserContextMiddleware trusts X-User-Id header without server validation. Any client can
MED-03	Critical	977069-35[MEDIA]	Dev mode uses weak fallback HMAC key. If JEFREY_ENV misconfigured in prod, events u
MED-04	Critical	977069-35[MEDIA]	Tool output NOT sanitized by content_guard. If tool output contains injection, it passes to L

#	Severidade	Arquivo	Descricao
MED-05	Critical [MED-05] Locked for	97706	DNS blocking misses: 0.0.0.0, DNS rebinding, some IPv6 variants.
MED-06	Critical [MED-06] Race condition	97706	SELECT FOR UPDATE on approve. Race condition: two concurrent approves both see
MED-07	Critical [MED-07] Race condition	97706	UI memory search sends Bearer token but no X-User-Id. Middleware sets user_id='anony
MED-08	Critical [MED-08] Race condition	97706	Graph checkpoints use thread_id without user_id namespace. Thread_id collision sha

#	Severidade	Arquivo	Descricao
LOW-01	INFORMATIVA	6885B11-w.py[80X105]	Dead code after exception block — unreachable logger.warning and return.
LOW-02	INFORMATIVA	5728C0-py128	url strips /v1 suffix. Breaks vLLM/LiteLLM endpoints.
LOW-03	INFORMATIVA	977060-py-ap[155-160]	memory/health returns global count when user_id=None (system path). Info leak.

Recomendacoes Priorizadas

P1 — Corrigir AGORA (Critica/Alta)

Achado	Correcao	Esforco
CRIT-01	Remover classes AgentState duplicadas, manter 1 classe com __getattr__ / __setattr__ corretos	3h
CRIT-02	Reescrever agent.run() para usar LangGraph com tool calling real (Ollama function calling)	6h
HIGH-02	Criar _embed() usando Ollama embeddings endpoint ou sentence-transformers	3h
HIGH-03	Substituir ORDER BY importance por pgvector cosine_distance operator	2h
HIGH-04	Incluir password na Redis URL (config.redis.dsn must include password)	1h
CRIT-04/05	Trocar PolicyEngine.decide() por PolicyEngine.evaluate() ou criar decide() alias	1h
HIGH-01	Corrigir mm.long_term.search() -> mm.search(), remover .get_messages()	1h
MED-07	CLI: adicionar X-User-Id header em get_auth_headers()	1h

Estimativa total P1: ~19 horas

P2 — Proximo Sprint (Media)

- MED-01: Persistir _RUNNING_TASKS em Redis/Postgres
- MED-02: Remover X-User-Id trust, usar user_id do token validado
- MED-03: Validar JEFREY_ENV em startup (fail-closed se nao e 'prod')
- MED-04: Aplicar content_guard no output do LLM antes de retornar
- MED-05: Expandir SSRF blocklist (0.0.0.0, DNS rebinding)
- MED-06: Adicionar SELECT FOR UPDATE no approve
- MED-08: Namespacar checkpoints com user_id:thread_id

P3 — Backlog (Baixa/Informativa)

- LOW-01: Remover dead code apos exception block no auth_middleware
- LOW-02: Configurar base_url para preservar /v1 quando necessario
- LOW-03: Auditoria de memory/health isolation por tenant

Riscos Latentes

Risco	Impacto	Severidade
_RUNNING_TASKS em producao com Tasks pendentes	Tasks pendentes apos restart. Clientes veem 'idle' durante conversas	BAIXA. Em escala multi-tenant, in
Stubs OAuth Google (calendar/email)	Falha silenciosa quando usuario tenta conectar Google Calendar/Gmail. User vê erro generico se	MÉDIA
smoke_test 5/7 com Ollama offline	5 de 7 testes passam mesmo sem LLM. Gera falsa sensacao de sucesso	BAIXA. Em CI/CD, deploy passa sem LLM
Agent sem LangGraph real	Em producao, o agent e apenas um wrapper de httpx para Ollama	CRÍTICA. Uma ferramenta e executada. Qu
Embeddings inexistentes	pg_memory._embed() nao existe. Nenhuma memoria e indexada	CRÍTICA. Contexto de memória vazio para sempre

Issues para GitHub

--- ISSUE: [CIPHER] CRIT: AgentState triplo + agent bypass governance ---

Labels: cipher, critica, P2

Problema: agent.py contem 3 definicoes de AgentState (edicoes falhas). A ultima __setattr__ conflita com __init__. agent.run() bypassa TODA a governanca (RBAC, Policy, HITL, Audit) fazendo httpx direto ao Ollama.

Evidencia: src/jefrey/core/agent.py:23-60 (triple class), :160 (bypass)

Correcao: Remover classes duplicadas. Reescrever run() usando LangGraph com tool calling real.

Critérios de Aceite:

- [] AgentState tem 1 definicao unica
- [] AgentState(user_id='test').user_id retorna 'test'
- [] agent.run() chama pelo menos 1 tool via ToolRegistry
- [] Audit log registrado apos execucao de tool

--- FIM ISSUE: [CIPHER] CRIT: AgentState triplo + agent bypass governance ---

--- ISSUE: [CIPHER] CRIT: pg_memory._embed() inexistente + search sem similaridade ---

Labels: cipher, critica, P1

Problema: pg_memory.add() chama self._embed() que nao existe. search() usa ORDER BY importance em vez de cosine distance.

Evidencia: src/jefrey/core/pg_memory.py:55 (_embed), :85 (search)

Correcao: Implementar _embed() com Ollama embeddings. Trocar ORDER BY por pgvector <=> operator.

Cr terios de Aceite:

- [] memory.add() persiste embedding no Postgres
- [] memory.search() retorna por similaridade coseno
- [] Teste: add 3 memorias, search retorna a mais similar primeiro

--- FIM ISSUE: [CIPHER] CRIT: pg_memory._embed() inexistente + search sem similaridade ---

--- ISSUE: [CIPHER] ALTA: STT/TTS chamam PolicyEngine.decide() inexistente ---

Labels: cipher, alta, P1

Problema: stt.py e tts.py chamam pe.decide() mas PolicyEngine so tem evaluate(). Ambos endpoints retornam 500 sempre.

Evidencia: src/jefrey/api/stt.py:40, src/jefrey/api/tts.py:40

Correcao: Criar alias PolicyEngine.decide() ou trocar para evaluate().

Cr terios de Aceite:

- [] POST /stt (com auth) retorna transcript

[] POST /tts (com auth) retorna audio bytes

--- FIM ISSUE: [CIPHER] ALTA: STT/TTS chamam PolicyEngine.decide() inexistente ---

--- ISSUE: [CIPHER] ALTA: Rate limiter deny all (Redis URL sem password) ---

Labels: cipher, alta, P1

Problema: redis.dsn gera URL sem password. Redis exige auth. is_allowed_sync() raise RuntimeError -> fail-closed deny -> todas tools bloqueadas.

Evidencia: src/jefrey/core/rate_limit.py:~45, src/jefrey/core/config.py (redis.dsn)

Correcao: Incluir password na redis.dsn ou usar JEFREY_REDIS__URL com password.

Critérios de Aceite:

[] Rate limiter conecta ao Redis com sucesso

[] Tools nao sao bloqueadas indevidamente

--- FIM ISSUE: [CIPHER] ALTA: Rate limiter deny all (Redis URL sem password) ---

--- ISSUE: [CIPHER] ALTA: Skills sem user_id - cross-tenant data leak ---

Labels: cipher, alta, P6

Problema: Apenas notes.py propaga user_id. Automation, calendar, drive, email, web_search salvam dados sem user_id. Dados de usuarios misturados.

Evidencia: src/jefrey/skills/*.py (todos exceto notes.py)

Correcao: Adicionar user_id como parametro obrigatoria em todas as skills. Propagar user_id de kwargs.

Critérios de Aceite:

[] Todas skills tem user_id no signature

[] Audit log registra user_id em todas as chamadas

--- FIM ISSUE: [CIPHER] ALTA: Skills sem user_id - cross-tenant data leak ---